

Vulnerability Management Standard

Document ID: sec-vulnerability-management-standard. Owner: IT Security (Head of IT Security: Mei-Ling Tan). Effective date: 1 October 2024. Applies to: all Meridian-managed servers, endpoints, network devices, cloud workloads (including TesseraCloud) and product firmware (Halcyon, Tessera, Lumen).

Purpose

This standard sets out how vulnerabilities are discovered, rated, assigned and remediated, and the maximum time allowed to remediate each severity.

Discovery

- Authenticated infrastructure scans run weekly (Sunday 04:00 UK) against all server subnets at Leeds, Rotterdam, Austin and Penang.
- The Penang OT network (10.41.0.0/16) is scanned passively only; active scanning of production line equipment is forbidden without a change approved by the Penang factory manager.
- Container images built in Forge are scanned at build time; builds with unremediated critical findings fail the pipeline stage security-gate.
- TesseraCloud external attack surface is scanned daily.
- Product firmware SBOMs are checked against new advisories daily; firmware vulnerabilities follow the Product Security process owned by Engineering.

Severity rating

Findings are rated with CVSS v3.1 base score, adjusted by IT Security for exposure (internet-facing, internal, isolated).

Rating | CVSS base score | Remediation deadline (internet-facing) | Remediation deadline (internal)

Critical | 9.0 to 10.0 | 72 hours | 7 days

High | 7.0 to 8.9 | 7 days | 30 days

Medium | 4.0 to 6.9 | 30 days | 90 days

Low | 0.1 to 3.9 | 90 days | Next scheduled maintenance

Any vulnerability listed in a government known-exploited-vulnerabilities catalogue is treated as Critical regardless of score.

Assignment and tracking

Findings are raised automatically as Beacon tickets in category SEC-VULN and routed to the owning resolver group from the CMDB. The owning team must acknowledge within two business days. Critical internet-facing findings are also declared as a SEV2 incident.

Patching windows

Routine patches are deployed through the standard change catalogue (standard change SC-004, monthly OS patching) in the second week of each month. Out-of-cycle patches for Critical findings may use the emergency change path (CHG-EMERG) described in the Change Management Procedure.

Exceptions

If a deadline cannot be met, the owner raises a Beacon ticket in category SEC-EXCEPTION with

compensating controls. Exceptions for Critical findings require approval from the Head of IT Security and the CTO and are limited to 30 days. Exceptions for High, Medium and Low findings require Head of IT Security approval and are limited to 90 days.

Reporting

IT Security publishes a monthly vulnerability dashboard showing open findings by site and age. Findings older than their deadline are escalated to the site IT lead and to the CTO at the monthly Technology Risk Review.